

Security Trust Center - Vendor Assessment

WHAT : Vendor assessment for a SaaS Solution for hosting Lean Security Trust Center repository , shareable with external partners and customers

WHY: Lean Security Posture to be easily shared with external partners, customers, regulators. This will an industry standard (e.g. see Paid) and this portal will be present in our newly created /security page , from Lean Website. This will also serve as a good marketing campaign when announcing this to our clients

Requirements

- Upload evidences (reports, policies, self assessments)
- Risk posture
- Link with auditors and regulators
- Break down on security domains
- Access request (split per Private, Public)
- Dashboards

Vendor Comparison

Vendor	Meeting Functional Requirements	Score (1 to 5)	Cost
SafeBase	Yes	5	Starter : Free up to 50 clients (does not have all features) Growth : 3500 USD/year for 50 clients
Drata	Yes	5	10k/year

Security Due Diligence

ID	Security Requirements	Safebase	Drata
1	Role-based access controls	Yes	Yes
2	No shared accounts	Yes	Yes
3	Single Sign-On (either using Lean Identity Provider or other trusted IDP : Suite, Github, etc)	Yes (for paid version)	Yes (for paid version)
4	Audit mechanism	Yes	Yes
5	SW deployed behind Lean VPN (unless the business case mandates external exposure)	SaaS	SaaS
6	What Lean data will the platform have access to? Will the platform store any Lean sensitive data?	Yes, sensitive data from security reports and network diagrams/flows.	Yes, sensitive data from security reports
7	Multi Factor Authentication (MFA)	No	Yes
8	Maintained repository or an active community supporting the project	N/A	N/A
9	Due diligence on any previous security incidents or data breaches. Can a recent pentesting report be provided?	No security incidents. Pentesting report provided.	No security incidents. Pentesting report provided.
10	Vendor has GDPR and or ISO certifications	Yes,ISO 27001 certification	Yes,ISO 27001 certification, SOC-2

ID	Security Requirements	Safebase	Drata
11	Vendor has security SLAs (e.g. availability, security incident response, vulnerability management, etc)	Yes	Yes
12	The community should have a process in place for addressing reported security vulnerabilities	N/A	N/A
13	Scan (using SAST/SCA tool - Snyk) the open-source SW (e.g. by duplicating the Github repository)	N/A	N/A